

Table 2: Kubernetes Pod Security Standards (PSS) levels (Source: <https://kubernetes.io/docs/concepts/security/pod-security-standards/>)

| Level      | Description                                                            | Typical controls enforced                                                  |
|------------|------------------------------------------------------------------------|----------------------------------------------------------------------------|
| Privileged | Unrestricted policy, provides the widest possible level of permissions | None — intended only for system/infra workloads                            |
| Baseline   | Minimally restrictive; prevents known privilege escalations            | Blocks host namespaces, privileged containers, most host mounts            |
| Restricted | Heavily restricted; follows current pod-hardening best practice        | Requires runAsNonRoot, drops all capabilities, blocks privilege escalation |

patched the issue and notified affected customers to rotate credentials; no in-the-wild exploitation was reported. This demonstrates why container and node hardening (Table 2) and keeping the underlying container runtime patched are just as critical in managed and multi-tenant Kubernetes offerings as in self-managed clusters.

▪ **Dero cryptojacking campaign — Anonymous API access (2024)**

More recently, an automated campaign distributing the Dero cryptominer was observed scanning the internet for Kubernetes API servers that still permitted anonymous, unauthenticated access. Where such clusters were found, the attackers used that open access to pull and deploy malicious container images directly from public registries, turning the victim's own compute capacity into a mining botnet without ever needing to steal a credential. This maps directly to the RBAC authorisation flow in Figure 3 — a cluster with anonymous access effectively has no authorisation step at all — and to the admission-control guidance, since restricting which registries and images may be deployed would have blocked the attack outright.

Kubernetes security is best understood as a layered, ongoing discipline rather than a single setting. Securing the cluster requires coordinated controls at every level of the 4C's (Cloud, Cluster, Container, Code) model: hardened cloud/IAM foundations, least-privilege RBAC, default-deny network segmentation, restricted pod security standards,

encrypted and externally managed secrets, policy-enforcing admission controllers, continuous audit logging, and a secured software supply chain feeding trusted images into the cluster.

Organisations that treat these controls as a connected system — rather than isolated checkboxes — are best positioned to operate Kubernetes safely at production scale. **END** 🐧

## References

- Kubernetes Documentation — 'Kubernetes Components', <https://kubernetes.io/docs/concepts/overview/components/>
- Kubernetes Documentation — 'Overview of Cloud Native Security', <https://kubernetes.io/docs/concepts/security/overview/>
- 'Kubernetes Documentation — 'Using RBAC Authorization', <https://kubernetes.io/docs/reference/access-control/rbac/>
- Kubernetes Documentation — 'Pod Security Standards', <https://kubernetes.io/docs/concepts/security/pod-security-standards/>
- Wiz Academy — 'Kubernetes RBAC Best Practices — From Basic to Advanced', <https://www.wiz.io/academy/container-security/kubernetes-rbac-best-practices>
- Sysdig — 'Kubernetes Security 101: 10 Best Practices and Fundamentals', <https://www.sysdig.com/learn-cloud-native/kubernetes-security-101>
- Networkers Home — 'Kubernetes Security — RBAC, Policies, Admission', <https://www.networkershome.com/fundamentals/cloud-security/kubernetes-security-rbac-policies-admission/>
- Atmosly — 'Kubernetes Security Checklist: 50 Best Practices (2025)', <https://atmosly.com/blog/kubernetes-security-checklist-50-best-practices-2025>
- KodeKloud — 'Kubernetes Best Practices 2025: Optimize, Secure, and Scale', <https://kodekloud.com/blog/kubernetes-best-practices-2025/>
- Emircan Agac (Medium) — 'Kubernetes Security Best Practices Part 1: RBAC, Secrets & Pod Security', <https://medium.com/@emircanagac/kubernetes-security-best-practices-part-1-1d7ef1566f25>
- Greenberg, Andy — 'How Hacked Water Heaters Could Trigger Mass Blackouts'/ Tesla cryptojacking coverage, Wired, <https://www.wired.com/story/cryptojacking-tesla-amazon-cloud/>
- Unit 42, Palo Alto Networks — 'Azurescape: Cross-Account Container Takeover in Azure Container Instances', <https://unit42.paloaltonetworks.com/azure-container-instances/>
- Vectra AI — 'Kubernetes Security Risks and How to Detect Them' (Dero cryptojacking campaign, 2024), <https://www.vectra.ai/topics/kubernetes-security>
- ropnop Blog — 'Attacking Default Installs of Helm on Kubernetes', <https://blog.ropnop.com/attacking-default-installs-of-helm-on-kubernetes/>

## By: Dr Geetali Saha and Kush Patel

**Dr Geetali Saha** is a faculty member at the Department of Electronics & Communication, GCET, CVM University, Anand, Gujarat.

**Kush Patel** is a member of the faculty in the Department of Information Technology, GCET, a PhD Scholar at CVM University, Anand, Gujarat. He is an expert in security applications.